User permissions and improvement register

One reference for the six existing roles, Engineer submission, review decisions and role-specific follow-up.

Scope: improve what is already developed.
No additional product modules are included.

Engineer > QA Engineer > Team Lead > Client (when required) > Closed

This document separates permitted actions, prohibited actions, confirmed repairs and remaining verification gaps. AI Analysis supports review and never grants an engineering approval.

The Super Admin role is included as the owner’s administration role. It does not substitute operational or technical reviewers.

Use the PDF bookmarks to find a role. Current permission claims are based on server checks and isolated regression journeys; they do not establish production or whole-site engineering acceptance.

Review date: 23 October 2026. Scope: the existing Django survey and inspection application. This guide describes six current roles and the existing review workflow; it is not a plan for additional modules or a production-readiness certificate.

The permission, routing and Engineer workspace checks below were executed against isolated Django records. Desktop and mobile browser checks used synthetic survey evidence; they do not establish field-device acceptance, native AI accuracy or production readiness.

How access is decided

An active, unlocked operational account needs an effective project grant. A grant can expire or be revoked; an old primary-project value does not restore a revoked grant. Company boundaries apply to project staff. Admin access is additionally limited to the owning Admin's projects and assigned industry. Multiple project access requires explicit permission. Super Admin has separate platform-administration authority; even global administrative visibility does not grant operational engineering access.

Being able to see a project does not permit every operation on its tasks. Engineer ownership, named QA/Team Lead/Client reviewers, current workflow stage, frozen revision, approved sections and stale-request checks are evaluated again by the server. Hiding a button is not the permission boundary.

Existing action	Super Admin	Admin / Project Manager	Engineer	QA Engineer	Team Lead	Client
Platform industries, Admin provisioning and global access maintenance	Yes	No	No	No	No	No
Create company projects and choose project approval layers	No	Own company and industry	No	No	No	No
Create Client organizations or invite Clients	No	Managed company projects	No	No	No	No
Create single/bulk site tasks	No	Managed projects	No	No	Assigned projects	No
Develop and publish checklist templates	No	Managed template scope	No	No	Technical qualification only	No
Edit survey answers and upload evidence	No	No Engineer signature	Assigned editable task	No	No	No
Submit opted-in survey for AI Analysis	No	No	Assigned editable task, completed intake	No	No	No
Accept or correct generated Engineer proposals	No	No	Assigned editable task	No	No	No
Sign QA review	No	No	No	Named QA at current stage	No	No
Sign Team Lead review	No	No	No	No	Named Team Lead at current stage	No
Sign Client approval	No	No	No	No	No	Named Client after sharing
Release generated drawing outputs	No	No	No	Technical package review only	Assigned Team Lead after all release gates	No

Existing action	Super Admin	Admin / Project Manager	Engineer	QA Engineer	Team Lead	Client
Open operational tasks/evidence	No	Scoped administrative inspection	Own tasks	Assigned review tasks	Assigned review tasks	Shared current revision only
Read published staff work profiles	Administrative account view	Shared-project staff	Shared-project staff	Shared-project staff	Shared-project staff	Eligible published shared-project profiles

The matrix summarizes the current governed workflow. Retained historical workflows have their original named reviewers and signatures; they are not silently converted into a new route.

Older records explicitly using legacy governance retain their original editing rules: a scoped Admin or Team Lead can edit an unfinished legacy checklist, while final records and approved sections remain locked. This exception was checked through isolated HTTP saves; it does not grant an Engineer signature in the current governed workflow. A template with Checklist required switched off is not necessarily a legacy-governance record: the AI setting and approval policy are separate.

Historical version-one independent workflows can retain their original named Team Lead validation and Project Manager approval. New governed routes use Engineer, QA Engineer, Team Lead and the optional Client. Never infer a current operational permission from an old stored role label or rewrite a historical signer to fit the new route.

iSurvix

Engineer

Purpose and permitted work

- Find assigned tasks and distinguish pending preparation, submitted/review work, returned or rejected corrections, and completed work. The workflow stage and AI processing status are separate.
- Open an assigned task's published checklist snapshot. Use Group, Section and Checkpoint navigation without changing the controlling template.
- Complete permitted site answers, upload camera/gallery photos in bounded batches, inspect originals and previews, and confirm or correct evidence links when the task is editable.
- Leave the old Civil/Electrical/Tower upload label empty. Those optional storage labels are not the checklist hierarchy or a technical decision about the photograph.
- Engineer uploads are upload-only in the simplified interface. Use the third-step submission action after the current browser's uploads and saves finish; uploading files alone does not approve a task or start analysis.
- For a survey whose published template enables Checklist required, this action enters the durable integrated survey pipeline. Other existing surveys use their existing photo-job API through a separate explicit AI submission action rather than being silently converted into the drawing pipeline.
- Review proposed answers, their sources and uncertainty. Correct or reject unsupported values and explicitly complete the Engineer review before the technical QA hand-off.
- Correct a returned task and submit a new retained revision. Prior inputs, evidence, review events and signed revisions remain available.
- Maintain their own professional profile and experience. Published experience is self-reported, not application-certified competence.

Not permitted

The Engineer cannot create projects, administer Clients or staff, publish templates, edit another Engineer's task, sign QA/Team Lead/Client decisions, release drawings, or change frozen/approved evidence through upload or answer endpoints. AI suggestions are not Engineer approvals. A required unsupported answer remains an unresolved submission requirement rather than an invented pass or dimension.

Current issues and follow-up

Type	Status	Existing-feature follow-up
Crowded upload/checklist/submission screens	Fixed for the checked journeys; desktop and mobile verification passed	Three clear steps separate tasks, checklist/photos and submission. Checks cover uploads without automatic AI, tree selection, failed saves and upload navigation guards. After accepted results are applied, the old intake panel is hidden and the existing Send to QA action is focused and shown immediately above the review area.
Mobile checklist drawer could not be opened in the first browser capture	Fixed; fresh independent browser verification passed	The first capture used a cached template. After a fresh server render, the 390px drawer opens with search focus and correct expanded state, Group/Section controls work, and checkpoint selection opens the correct answer pane and closes the drawer. No outer horizontal overflow was found.
Disabled submission buttons had faint/unreadable labels	Fixed; independent browser and visual verification passed	Disabled legacy submission uses dark text (#43556d) on a light background (#e4eaf2), with full opacity. Keep unavailable actions clearly labelled.
AI starts through a historical retry/critique path before canonical submission	Reproduced and repaired in this change; focused regressions passed	Keep the server guard for opted-in surveys and preserve historical records.
Native processing crash, audit A12	Open integration issue	An earlier native exit139 has no established root cause. Passing Windows tests do not close the issue; obtain a supported reproduction/backtrace and compatible native dependency evidence.
Complete real-site AI accuracy and speed	Not yet accepted	Measure full authorized site batches, incorrect/missed matches, correction effort, retry/restart behavior and actual elapsed processing time. Small synthetic uploads do not prove AI throughput.
Phone/network usability	External validation remains	Exercise real Android/iPhone capture, intermittent signal, interrupted batches, offline messages and retry recovery.
Concurrent legacy/excluded uploads in another tab or browser	Existing hardening gap	The simplified legacy interface checks its own upload/save activity and asks for completion confirmation. Durable cross-browser upload-session tracking currently belongs to the opted-in pipeline; do not claim equivalent protection for legacy or inspection uploads.

QA Engineer

Purpose and permitted work

- Open tasks where they are the named QA reviewer and still have effective project access.
- Inspect submitted answers, source photographs, checklist dispositions and retained revision history.
- Approve the current technical review or return it one step to the Engineer with a reason. A stale token or a change to frozen source inputs blocks a decision.
- In an opted-in AI/drawing package, independently approve or reject the exact Engineer-reviewed technical package. This is distinct from a checklist result or overall task status.
- Inspect approved sections and retained evidence without modifying the Engineer's submission.
- Maintain their own professional profile, qualifications and experience and choose whether to publish it to eligible shared-project colleagues.

Not permitted

QA cannot create projects or tasks, invite staff/Clients, upload or replace an Engineer's evidence through their account, accept the Engineer's AI proposals, sign the Team Lead/Client decision, or release drawing outputs. QA and Engineer must be distinct actors.

Current issues and follow-up

Type	Status	Existing-feature follow-up
Current-stage and named-reviewer protection	Verified in isolated workflow checks	Keep denials for wrong reviewer, revoked access, stale decisions and changed inputs.
Technical accuracy of AI findings	Field validation remains	Independently compare real findings and missing/conflicting information with checked site evidence and acceptance criteria.
Historical scientific values	Impact review remains	PR13 fixes conversion and reconciliation going forward. Previously stored or signed results were not rewritten; review any suspected historical impact against originals.
Native processing stability	Open shared issue, A12	QA should not treat a successful retry as resolution of an unexplained native crash.

Team Lead

Purpose and permitted work

- Create and assign single or bulk site tasks within effective project access. The task inherits the project's published checklist and three- or four-layer policy.
- Select the Engineer and required named reviewers from permitted project members during the authorized initial task setup. Existing frozen reviewer routes cannot be silently changed.
- Record technical qualification of the applicable checklist/template against the relevant specification and method when required by the workflow.
- Review work after QA approval. Approve it to the next stage or reject one step to QA with a reason.
- Receive a Client rejection as a Team Lead clarification. Clarify and resubmit to the Client if source inputs remain unchanged, or return one step to QA when further correction is needed.
- Release the exact drawing package only after explicit Engineer completion, an independent assigned QA package decision, closed task routing and required Client approval.
- Choose whether to share the separate checklist critique with the Client through the existing explicit sharing control. Internal photo-model diagnostics remain private.

Not permitted

The Team Lead cannot create company projects, administer account roles, act as the Engineer or QA signer, bypass required Client approval, edit frozen source inputs to conceal a correction, publish the controlling checklist, or release an unchecked package. Project membership alone does not replace named-reviewer assignment.

Current issues and follow-up

Type	Status	Existing-feature follow-up
One-step rejection and clarification	Verified in isolated three/four-layer journeys	Keep the source revision, decision history and required reason through each return.
Readability and completeness of drawings	Engineering/CAD acceptance remains	Use measured units and source-backed geometry. Review actual CAD imports, fonts, Arabic/mixed labels, missing dimensions and customer-approved details.
Manufacturer/site geometry	Reference dependency remains	Approved manufacturer blocks and checked site measurements are needed before claiming installed accuracy. Unsupported sheets remain draft/not to scale.
Real field/team review experience	External validation remains	Confirm the simplified Engineer hand-off reduces effort without hiding uncertainty or required evidence from reviewers.

Client

Purpose and permitted work

- View only project information and current task revisions that are appropriately shared with their named Client account.
- Inspect submitted source evidence, confirmed links, final answers and any separately shared checklist critique.
- Approve or reject at the Client stage of a four-layer route. A rejection requires a reason and returns to the Team Lead, not directly to the Engineer.
- Open permitted released PDF/DXF outputs. Draft outputs and private internal AI proposal/reasoning/job diagnostics are excluded from the Client projection.
- Read eligible published Engineer/QA/Team Lead/Admin work profiles when both parties retain a shared project. Unpublished profiles and revoked affiliations are not available.
- Maintain their own basic professional profile without changing their account role or grants.

Not permitted

Clients cannot upload or edit Engineer evidence, accept AI proposals, sign QA/Team Lead decisions, release drawing packages, create or assign tasks, manage accounts/templates, view another named Client's independent deliverable, or access private files through direct media paths. A three-layer project has no Client approval stage.

Current issues and follow-up

Type	Status	Existing-feature follow-up
Internal photo/AI information exposure	PR13 repair verified by Client-privacy regressions	Continue denying pending/rejected proposal details, internal reasoning, provider metadata and job diagnostics.
Matching/confirmation wording on a read-only Client page, A13	Fixed for the reported matching panel; independent regression and browser checks passed	The page identifies Submitted evidence and hides the editable matching queue for Clients. Submitted source photographs and their authorized original downloads remain available. Engineer and Team Lead matching surfaces are preserved.
Client sharing and approval usability	Stage-specific checks passed; physical-device acceptance remains	Test the actual customer device and clarify which revision, evidence and outputs are being approved.

Admin / Project Manager

Purpose and permitted work

- Manage company projects within the Super Admin-assigned industry and project ownership/grants. One Admin may own multiple projects; another Admin does not gain access merely by sharing a company.
- Create projects, select their published checklist and choose a three- or four-layer approval route before task creation.
- Create Client organizations, associate them with permitted projects, and invite Engineers, QA Engineers, Team Leads and Clients to managed projects.
- Grant, revoke or expire project memberships within company/industry boundaries. Additional project access is explicit.
- Create single/bulk site tasks and record the basic site information that flows into matching checklist fields.
- Develop checklist drafts, use standard/reused section/checkpoint recommendations, replicate revisions, configure input/evidence rules and publish permitted templates. Used structures and historical task snapshots remain protected.
- Move a checkpoint between real sections/activities in an eligible editable draft while retaining its field identity and evidence rules. Keep every section valid; unpublish an unused published revision before editing, and replicate protected used structures instead of rewriting historical tasks.
- Disable/enable scoped templates. Unpublish an unused template before editing or deletion; deletion also requires removing project-default references. In-use or historically referenced templates remain protected and can be replicated or disabled instead.
- Manage permitted company/client branding and inspect scoped administrative audit history.
- Activate/deactivate or unlock eligible staff where all of the account's affiliations are within their management scope; use scoped revocation when wider affiliations prevent a global account action.

Not permitted

An Admin cannot change their own industry, create Super Admin/Admin invitations, convert a Client into another role through membership controls, access foreign-company or another Admin's private projects, or substitute an Engineer/QA/Team Lead/Client technical signature. They cannot directly rewrite immutable audit events or approved historical templates/records.

Current issues and follow-up

Type	Status	Existing-feature follow-up
Broad checklist terminology and Engineer overload	Existing-editor refinement verified by focused regressions	The draft editor can move a checkpoint to another section/activity while preserving its stable ID and evidence/input settings; published or used templates remain locked. Group/Section/Checkpoint navigation is verified in the Engineer workspace. Existing real checklist content was preserved.
Legacy Project Manager transition	PR13 implementation; actual-target review required if legacy accounts exist	New roles use Admin / Project Manager. Ambiguous industry/company bindings remain deferred; never guess scope or rewrite signed historical reviewers.
Older intentional/failed-login locks	Operator review if present	Temporary throttling does not prove why an older real account was locked. Do not bulk-unlock historical accounts.
Backup/recovery and hosted operation	Operational acceptance remains	Rehearse a consistent restore of database, originals, outputs and job state; verify scoped HTTPS/PC-worker operation and retention procedures.

Super Admin

Purpose and permitted work

- Maintain platform industries, codes, descriptions and administrative company records.
- Provision industry-specific Admin accounts, bind their industry and assign the owning project administrator through the existing global controls.
- Review administrative project/site identifiers, global account/grant audit history and eligible access-maintenance controls.
- Grant/revoke permitted administrative project access and manage eligible account activation/locks. Administrative invitation controls may provision project staff except Clients; this does not confer a technical signature.
- Perform the existing explicitly confirmed access-maintenance reset, which concerns sessions/invitations/locks rather than deleting survey evidence or approving engineering work.
- Maintain their own basic profile.

Not permitted

Super Admin does not create company projects, create/invite Clients, use the operational task explorer or engineering exports, edit site answers/evidence, configure engineering reviewers, sign any technical or Client decision, or release drawings. Global administrative visibility is not operational approval authority. The shared-project professional directory is for operational users rather than Super Admin.

Current issues and follow-up

Type	Status	Existing-feature follow-up
Current release reference and older main	Release-selection work remains	Ensure the reviewed feature release is the installation source. An older main branch is not proof that the current security/workflow fixes are installed.
Historical global account privileges	Conditional operator review	If an older build granted global flags to company Admins, review the intended account authority explicitly. Current role/login repairs do not prove the history of old stored flags; never bulk-demote legitimate Super Admins.
Native crash and reproducible environment	Open integration issue	Identify the native crash cause; maintain supported Windows/Linux dependency and repeatable-test evidence.
Audit tamper boundary	Application guards verified; operational custody decision remains	Ordinary ORM edits/deletes are guarded. Privileged raw SQL/host control requires separately accepted retention and tamper-evidence procedures.
Production/privacy/device acceptance	Not certified by current tests	Approve staging, backups, token rotation, data retention, incident ownership and actual field-device acceptance before production promotion.

Submission and rejection workflow

For Checklist required surveys:

1. The Engineer completes permitted site inputs and uploads originals. Upload progress and completion are visible; an unfinished upload session blocks AI submission.
2. The Engineer explicitly submits the completed intake for AI Analysis. A durable saved revision/job is created. Repeating the same submission reuses that job/revision.
3. AI proposes checklist answers/evidence against stable fields from the published revision. Missing, uncertain and conflicting information stays visible; AI cannot approve itself.
4. The Engineer checks and explicitly accepts/corrects the result, then completes the hand-off to QA. AI processing status and technical workflow status remain distinct.
5. A three-layer task follows Engineer -> QA -> Team Lead -> Closed. A four-layer task follows Engineer -> QA -> Team Lead -> Client -> Closed.
6. A rejection moves one step back. Team Lead rejection goes to QA; QA can return to Engineer. Client rejection goes to Team Lead for clarification or another one-step return.
7. Changed Engineer inputs require a new retained AI/review revision and a new technical submission. Previous source snapshots and signed decisions remain intact.
8. Generated outputs remain draft until the exact package meets the technical review and release gates. An authorized Team Lead performs release; the Client receives only permitted released outputs.

Existing excluded surveys and inspection workflows retain their backend photo-job rules, but the simplified Engineer interface uploads first and requests AI explicitly from its submission step. It waits for the current browser's uploads/saves and asks for confirmation; it does not yet establish that another browser's legacy upload is complete. The integrated Checklist & Drawings gate and durable upload sessions apply only to published telecom-survey templates with Checklist required enabled; do not silently extend that pipeline to unrelated modules.

Verification evidence and limits

Current independent checks executed during this change:

- `core.test_engineer_submission_acceptance`, task creation, enterprise task acceptance and review workflow: 39 tests passed in 11.971 seconds.
- Company access, Client access/photo privacy, work profiles, Admin industry, Client Admin forms and audit integrity: 51 tests passed in 8.704 seconds.
- New independent acceptance plus submission-only boundary regression tests: 13 tests passed in 2.288 seconds after the backend guard change.
- Current task-bucket/editor/boundary/independent acceptance checks: 31 tests passed in 4.329 seconds. A subsequent six-test independent run passed in 1.810 seconds, including the same-record return path and rejection of an external return destination.
- The implementation lead's final complete backend run passed 828 tests in 276.207 seconds, with zero failures, errors or skips and native process exit 0. Django, migration-drift, dependency and all four retained frontend checks passed. Final command receipts are recorded in the release evidence.
- The implementation lead's real-browser artifacts record 14 upload checks, eight review/correction checks, seven closure checks and 11 mobile/role checks. Two deliberate save-failure responses returned HTTP 503 during the negative test; the failed answer remained visible and blocked submission. No unhandled JavaScript exceptions were recorded.
- The independent reviewer additionally ran 23 fresh read-only Edge checks at 390px and 1440px: mobile drawer visibility/focus/expanded state, Group and Section collapse/expand, correct checkpoint selection, no outer overflow, readable disabled submission, hidden alternate Engineer AI-launch controls, Client matching-card hiding with both submitted photos/original downloads retained, and no unhandled JavaScript exceptions. The corresponding screenshots were visually inspected.
- Browser review exercised the actual saved four-layer task: upload, explicit AI submission, Engineer correction/acceptance, QA approval, Team Lead rejection to QA, QA return to Engineer, a second retained revision, QA/Team Lead approval, Client rejection to Team Lead, clarification and Client approval. A separate three-layer task completed Engineer acceptance and hand-off, QA approval and Team Lead approval to closure. Six additional stage-ready browser checks verified the earlier QA hand-off action and hidden obsolete intake panel. Excluded-survey upload-only behavior has independent API coverage; its explicit AI submission was also exercised in the browser.
- The final combined independent journey, Client-privacy and submission-boundary run passed 24 tests in 2.722 seconds, with zero external connections. A separate isolated legacy-permission probe verified scoped Admin/Team Lead editing before Final and denial after Final, alongside the seven existing Client-privacy cases (eight tests passed in 0.552 seconds).
- The runs overlap; their counts are not added into a unique total. Browser artifacts and test counts identify their own scope and are not a universal defect-free claim.

These checks use temporary Django databases/media/model caches, actual application HTTP/service operations and controlled inference. The browser fixture used the real persisted job and drawing renderers to generate PDF/DXF outputs; native vision findings were controlled test data. They verify record persistence, permission failures, upload hashes/deduplication, queue idempotency, explicit Engineer acceptance, one-step rejection, revision preservation and closure policy. They do not establish real native-model accuracy, 500-photo sustained throughput, production hosting, physical-device accessibility or engineering compliance.

No operational survey approvals, user passwords, original evidence or historical released values were changed by these independent checks.